Passwortsicherheit, Entropie & Best Practices

Informatik | Kantonsschule im Lee

Laurin Ott

2. November 2026

Einstieg: Welches Passwort ist sicherer?

Passwort A

Sh5?L@

- Länge: $L = 6$
- Enthält Gross-/Kleinbuchstaben, Zahlen & Sonderzeichen

Passwort B

kamelregentischblauargentini-enschule

- Länge: $L = 36$
- Nur Kleinbuchstaben

Frage an die Klasse: *Welches Passwort hält einem Computerangriff länger stand und welches lässt sich besser merken?*

Ablauf & Zeitplan

Lektion 1 (45 Min.)

- **00–02 min:** Vorstellung & Warum ich hier bin
- **02–04 min:** Brute-Force Demo
- **04–06 min:** Abstimmung: Welches Passwort besser?
- **06–08 min:** Voting aufgelöst
- **08–23 min:** Entropie erklären (15 Min.)
- **23–38 min:** Aufgaben rechnen (15 Min.)
- **38–45 min:** Ende gerechnet / Besprechung

Lektion 2 (45 Min.)

- **00–05 min:** Start 2. Lektion / Diceware
- **05–15 min:** Nist Best Practices / MFA / Passwort-Manager
- **15–20 min:** Best Practices und MFA übungen (5 Min.)
- **20–30 min:** Aufgabe: HIBP & Passwortcheck (10 Min.)
- **30–45 min:** Umfrage ausfüllen (15 Min.)
- **Rest Zeit:** Artikel Passwort-Manager & Passwortspiel

Wie greifen Computer Passwörter an?

1. Brute-Force-Angriff

Ein automatisierter Angriff, bei dem Programme **systematisch alle möglichen Zeichenkombinationen** durchprobieren ($a, b, c \ldots aa, ab \ldots$).

2. Dictionary Attack (Wörterbuchangriff)

Ein gezielter Angriff, bei dem Listen mit **gebräuchlichen Wörtern, Namen, Daten und bekannten Passwörtern** durchgetestet werden.

Das Problem menschlicher Eingaben: Wir wählen vorhersehbare Muster (*z. B. Jahreszahlen, Grossbuchstabe am Anfang*). Der tatsächliche Suchraum für Angreifer schrumpft dadurch drastisch!

Multifaktor-Authentifizierung

Was ist MFA?

Multi-Faktor-Authentifizierung (MFA) ist ein Sicherheitsverfahren, bei dem Benutzer **mehrere unabhängige Faktoren**(z. B. Einmalcode oder App-Bestätigung) zur Verifizierung ihrer Identität bereitstellen müssen. MFA ist extrem effektiv, da Passwörter alleine für eine erfolgreiche Übernahme meist nicht ausreichen.

Vorteil: Selbst wenn ein Angreifer Ihr Passwort kennt, kann er ohne den zweiten Faktor nicht auf Ihr Konto zugreifen.

Die mathematische Grundlage: Shannon-Entropie

Was ist die Entropie (E)?

Die Shannon-Entropie misst den Grad der **Zufälligkeit** bei der Passwort-Generierung in der Einheit **Bit**. 1 Bit entspricht einer binären Ja/Nein-Entscheidung $(1/0)$.

Für Zeichen-Passwörter:

$$N = R^L$$

$$E = \log_2(N) = L \cdot \log_2(R)$$

Für Wort-Passphrasen:

$$N = W^L$$

$$E = \log_2(N) = L \cdot \log_2(W)$$

- L: Länge (Anzahl Zeichen bzw. Wörter)
- R: Größe des Zeichensatzes (z. B. $R = 26$ für Kleinbuchstaben, $R = 94$ für alle Zeichen)
- W: Anzahl der Wörter im Wörterbuch (z. B. $W = 7776$ bei Diceware)

Rechnen an der Tafel: Komplexität vs. Länge

Szenario A: Kurze Komplexität

- Länge: $L = 8$
- Zeichensatz: Alle Zeichen ($R = 94$)

$$E_A = 8 \cdot \log_2(94) \approx \mathbf{52{,}4} \text{ Bit}$$

Szenario B: Lange Einfachheit

- Länge: $L = 20$
- Zeichensatz: Nur Kleinbuchstaben ($R = 26$)

$$E_B = 20 \cdot \log_2(26) \approx \mathbf{94{,}0} \text{ Bit}$$

Mathematisches Fazit

Die Anzahl Möglichkeiten $N = R^L$ wächst **exponentiell** mit der Länge (L), aber nur **logarithmisch** mit dem Zeichensatz (R). **Länge schlägt Komplexität!**

Übersicht: Entropie für verschiedene Längen & Zeichensätze

Zeichensatz (R)	**Länge (L)**	**Formel**	**Entropie (E)**
Kleinbuchstaben ($R = 26$)	8	$8 \cdot \log_2(26)$	$\approx 37{,}6$ Bit
Alle Zeichen ($R = 94$)	8	$8 \cdot \log_2(94)$	$\approx 52{,}4$ Bit
Kleinbuchstaben ($R = 26$)	16	$16 \cdot \log_2(26)$	$\approx 75{,}2$ Bit
Kleinbuchstaben ($R = 26$)	20	$20 \cdot \log_2(26)$	$\approx 94{,}0$ Bit
Alle Buchstaben ($R = 52$)	20	$20 \cdot \log_2(52)$	$\approx 114{,}0$ Bit
Alle Zeichen ($R = 94$)	20	$20 \cdot \log_2(94)$	$\approx 131{,}1$ Bit

Hinweis: Umrechnung auf wissenschaftlichen Taschenrechnern: $\log_2(x) = \frac{\ln(x)}{\ln(2)} = \frac{\log(x)}{\log(2)}$

Arbeitsphase: Aufgabenblatt 1 (Teil 1 & 2)

Jetzt sind Sie dran!

Arbeitsauftrag (15 Minuten in Partnerarbeit)

1. Öffnet euer Skript auf **Seite 7** (Abschnitt 3.1).
2. Lösen Sie die **Aufgaben 1 und 3 bis 5** zur Entropieberechnung.
3. Nutzen Sie den Taschenrechner für die Logarithmen oder benutzen Sie das Entropierechner-Tool auf Moodle!

Das Diceware-Verfahren

Wie generiert man echte Zufalls-Passphrasen?

1. Würfelen Sie $5\times$ mit einem normalen 6-seitigen Würfel (z. B. 3-2-5-4-1).
2. Schlagen Sie das Wort in der Diceware-Liste(auf Moodle) nach ($W = 7776$ Wörter).
3. Wiederholen Sie das für 5 bis 7 Wörter.

Klassen-Passphrase

Bei 7 gewürfelten Wörtern:

$$E = 7 \cdot \log_2(7776)$$

$$E \approx \mathbf{90{,}5}\ \text{Bit}$$

Praktisch unknackbar!

Lektion 2: Hands-On Praxis-Check

Auftrag (10 Minuten am Laptop)

Öffnet die folgenden zwei Sicherheits-Tools und testet fiktive Beispiele:

1. passwortcheck.ch

- Testen Sie verschiedene Muster (z.B. `Sommer2026!` vs. gewürfelte Passphrasen).
- *Achtung:* Geben Sie niemals Ihre echten Passwörter ein!

2. haveibeenpwned.com

- Gehen Sie auf `haveibeenpwned.com/Passwords` und testen Sie einige häufige Passwörter (z. B. `123456` oder `Passwort1`), um zu sehen, wie oft es geleakt wurde.
- Scrollen Sie auf der Startseite herunter, welche bekannten Websiten/Plattformen hatten bereits grosse Datenlecks?
- (Freiwillig) Prüfen Sie mit eurer E-Mail-Adresse, ob ihr selbst von einem Datenleck betroffen wart.

Die 4 goldenen Regeln der Passwortsicherheit (NIST)

1. Länge vor Komplexität

Bevorzugung von Passphrasen aus mehreren zufälligen Wörtern.

2. Keine Wiederverwendung von Passwörtern

Jedes Konto benötigt ein einzigartiges Passwort (Schutz bei Datenlecks!).

3. Keine erzwungenen Änderungen ohne Anlass

Regelmässige Passwortwechsel führen zu schwächeren Mustern und Eselsbrücken.

4. Passwort-Manager & MFA nutzen

Zufällige Passwörter verwalten lassen und den 2. Faktor aktivieren.

Vielen Dank für eure aktive Mitarbeit!

Bitte scannen Sie den QR-Code an der Wandtafel oder nutzen den Link (auf Moodle), um mir ein kurzes Feedback zu den beiden Lektionen zu geben. Wenn Sie noch Fragen haben, stellen Sie diese bitte jetzt.

